

1. Cluster di attività di esercizio 2: Studio degli indicatori di compromissione (IoC)

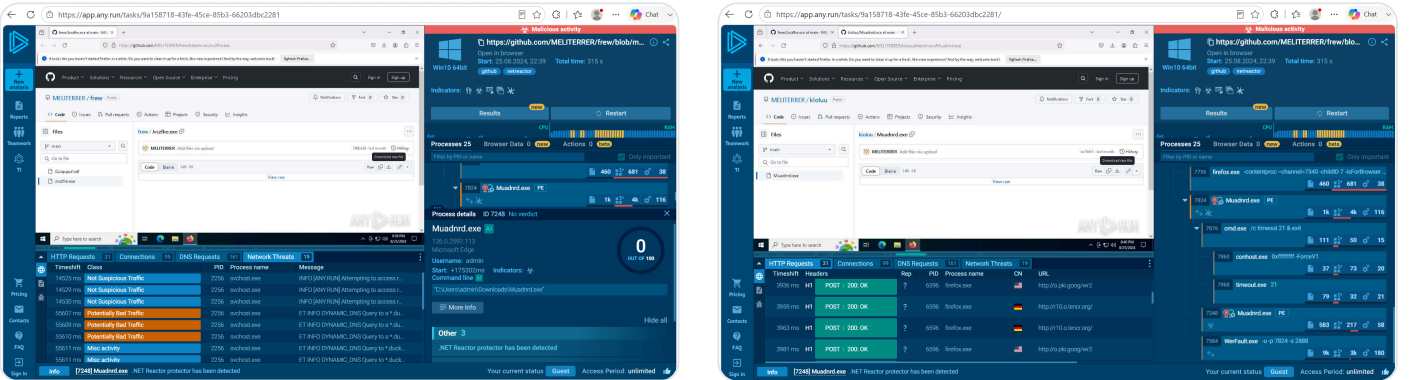
1.1. Ambito operativo

Per questo laboratorio sono nell'ambito operativo le attività di analisi dell'esecuzione dei software `Jvczfhe.exe` e `Muadnrd.exe` nell'ambiente *sandbox on-cloud ANY.run*, ovvero al collegamento <https://app.any.run/tasks/9a158718-43fe-45ce-85b3-66203dbc2281/>

Per le attività di analisi si è fatto riferimento alle analisi statiche e dinamiche eseguite dall'ambiente *sandbox on-cloud ANY.run*

1.2. Panoramica degli eseguibili

Nell'analisi di *open source intelligence* degli eseguibili `Jvczfhe.exe` e `Muadnrd.exe`, in particolare attraverso le istantanee di schermo presenti al collegamento <https://app.any.run/tasks/9a158718-43fe-45ce-85b3-66203dbc2281/>, si è notato che gli eseguibili `Jvczfhe.exe` e `Muadnrd.exe` sono stati parte della repository "*frew*"^[1] e "*kioluu*"^[2] dell'autore "*MELITERRER*" nella piattaforma *GitHub*. Tale repository, alla data di redazione di questo report risulta tuttavia non accessibile (si presume sia stata resa inaccessibile tra Agosto 2024 e la data di redazione del seguente report, settembre 2026).



Schermata dell'ambiente di *sandbox ANY.run*, nelle quali si notano l'analisi di open source intelligence e l'esecuzione dinamica degli eseguibili `Muadnrd.exe` e `Jvczfhe.exe`, ospitati rispettivamente all'interno dei repository *kioluu* e *frew* dell'autore *MELITERRER*. In particolare, le interfacce mostrano i dettagli dei processi attivi, gli indicatori di minaccia rilevati, l'albero dei processi correlati e i log relativi al traffico di rete catturato durante l'esecuzione dei campioni.

Nella stessa analisi, si è rilevato che i software `Muadnrd.exe` e `Jvczfhe.exe` sono identificabili tramite le seguenti stringhe:

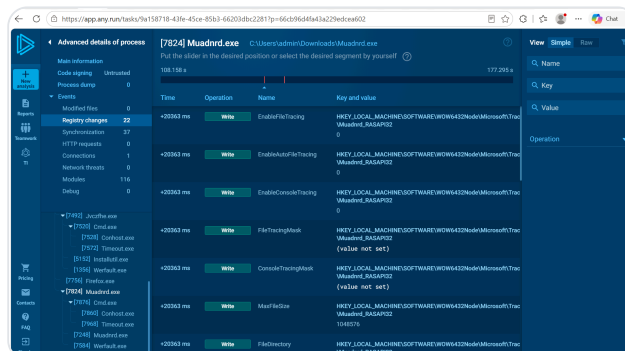
Nome dello eseguibile	Stringhe di <i>checksum</i> MD5 e <i>hash</i> SHA-256
Jvczfhe.exe	[MD5] 5ec4256e6a2367502a8058f4bc8f4ecc [SHA-256] e6a7aaff54eb6d06acfc6f1dfa21a85b767dbf7ff3e9bdfd2ddbdecdec86aa9b2
Muadnrd.exe	[MD5] 9773175646f2942573bb40551b142a99 [SHA-256] b662e7213f4985684439e655bd92ea4b9a1566e76712bb86e1238113a35b90a0

Inoltre si è rilevato che l'eseguibile `Muadnrd.exe` usa riferimenti al browser *Microsoft Edge* presumibilmente come tecnica di *masquerading* per tentare di superare i controlli superficiali presentandosi visivamente come un eseguibile non malevolo. Dall'analisi dei moduli, il software `Muadnrd.exe` risulta un eseguibile compilato dal framework *.NET* con possibile offuscamento del codice tramite *.NET Reactor*, essendo indicata nel report *ANY.run* la posizione di memoria `0x5530000` per l'invocazione di operazioni *NecroBit* la decrittazione dei metodi durante il *runtime*, presumibilmente per la presenza di metodi con prefisso `m_` riscontrati nelle sequenze esadecimali degli eseguibili nelle analisi PE svolte dall'ambiente di *sandbox*.

1.3. Tattiche, tecniche e procedure del malware (TTP)

- Dopo 20.363 secondi dal lancio del software `Muadnrd.exe`, all'alveare del registro `HKEY_LOCAL_MACHINE\SOFTWARE\WOW6432Node\Microsoft\Tracing\Muadnrd_RASAPI32` è assegnata alla chiave `EnableFileTracing` il valore `REG_NONE 0`. L'operazione è indice dell'invocazione da parte del software `Muadnrd.exe` ad una delle librerie dinamiche `rasapi32.dll` o `rasman32.dll` del componente *Remote Access Service* (RAS), che gestisce, nell'abstract, le connessioni di rete verso posizioni remote, e l'assegnazione della chiave `EnableFileTracing` con il valore `REG_NONE 0` è indice della disabilitazione prefinita del SO Windows del logging degli eventi di rete per il programma che ha invocato la libreria. Il prefisso (`Muadnrd`, nel caso di analisi) del sottoalveare (`Muadnrd_RASAPI32`, nel caso di analisi) è il nome dell'eseguibile che ha invocato una delle funzioni/metodi di una delle librerie dinamiche di tale componente. Nel caso del logging degli eventi di rete abilitato per il programma che ha invocato la libreria, il registro catturato includerebbe informazioni utili per l'analisi degli indicatori *Command & Control* (C2)
- Dopo 24.294 secondi dal lancio del software `Muadnrd.exe`, all'alveare del registro `HKEY_CURRENT_USER\SOFTWARE\Microsoft\Windows\CurrentVersion\Internet Settings\ZoneMap` sono assegnate le seguenti chiavi:
 - `ProxyBypass` : è assegnato il valore `1`
 - `IntratetName` : è assegnato il valore `1`
 - `UNCAsIntranet` : è assegnato il valore `1`
 - `AutoDetect` : è assegnato il valore `0`

Da tali assegnazioni è ipotizzabile la classificazione del software a malware *Trojan*, ed è ipotizzabile che il fine di tali operazioni sia la ricezione di risorse *World Wide Web* in ambito *Intranet* per ottenimento (*download*) e/o esecuzione di file arbitrari, e l'abilitazione di un proxy locale per la cattura e/o manipolazione del traffico di rete.



Schermata dell'ambiente di *sandbox ANY.run*, nelle quali si notano l'elenco delle operazioni di lettura e scrittura dei valori del registro di sistema

- Dopo 67.250 secondi dal lancio del software `Muadnrd.exe`, il processo invoca il software di segnalazione errori `WerFault.exe` con il comando `C:\WINDOWS\SysWOW64\WerFault.exe -u -p 7824 -s 2888`, dove con la modalità utente (`-u`) è segnalata un'eccezione di livello utente (`-u`) per la sessione 2888 (`-s 2888`) analoga al processo con identificativo (PID) 7824 (`-p 7824`). L'identificativo è relativo al processo del software `Muadnrd.exe`.
- In maniera del tutto analoga, dopo 21.008 secondi dal lancio del software `Jvczfhe.exe`, all'alveare del registro `HKEY_LOCAL_MACHINE\SOFTWARE\WOW6432Node\Microsoft\Tracing\Jvczfhe_RASAPI32` viene rilevata un'operazione sulla chiave `EnableFileTracing` forzandone il valore a 0 (tracciato in questo caso con tipologia `REG_DWORD`). Anche in questa circostanza, l'operazione segnala in modo evidente l'invocazione delle librerie RAS da parte dell'eseguibile `Jvczfhe.exe` (che presta il nome al prefisso del sottoalveare `Jvczfhe_RASAPI32`) per attuare la disabilitazione delle tracce di diagnostica di rete del sistema operativo.
- Dopo 21.041 secondi dal lancio del software `Jvczfhe.exe`, il processo esegue dei controlli per estrarre le informazioni riguardanti il server proxy di sistema e la policy di sicurezza del software. Tale comportamento conferma lo stesso pattern

di manipolazione delle impostazioni di connessione rilevato per `Muadnrd.exe`, riconducibile all'intento di ispezionare, manipolare il traffico o eludere i sistemi di difesa. A ulteriore supporto della classificazione di `Jvczfhe.exe` come componente malevolo altamente sospetto, il processo tenta successivamente di stabilire una connessione di rete su una porta inusuale. L'esecuzione causa inoltre un crash volontario o anomalo dell'applicazione, operazione seguita dalla generazione di un file di dump per la cattura degli errori salvato all'interno della directory utente al percorso

`C:\Users\admin\AppData\Local\CrashDumps\Jvczfhe.exe.7492.dmp`

- Dopo 36.890 secondi secondi dal lancio del software `Jvczfhe.exe`, il processo invoca senza argomenti il software di installazione di Windows `C:\Windows\Microsoft.NET\Framework\v4.0.30319\InstallUtil.exe`, e allo stesso tempo si è rilevata una connessione alla porta 7702 dell'indirizzo IP `91.92.253.47`, il quale si è rilevato che possegga lo *hostname* `THEZONEBG` e che il server fisico sia localizzato in Bulgaria.
- Dopo 37.225 secondi dal lancio del software `Jvczfhe.exe`, il processo invoca il software di segnalazione errori `WerFault.exe` con il comando `C:\WINDOWS\SysWOW64\WerFault.exe -u -p 7492 -s 2676`, dove con la modalità utente (`-u`) è segnalata un'eccezione di livello utente (`-u`) per la sessione 2676 (`-s 2676`) analoga al processo con identificativo (PID) 7492 (`-p 7492`). L'identificativo è relativo al processo del software `Jvczfhe.exe`.

1.3.1. Eventi di Rete e Connessioni Command & Control (C2)

L'analisi del traffico di rete e delle risoluzioni dei nomi di dominio ha evidenziato un'attività di *beaconing* costante e strutturata, riconducibile alle fasi di *Command and Control* (C2). I processi analizzati nell'ambiente di *sandbox* hanno avviato molteplici richieste DNS verso domini esterni con un basso grado di fiducia, integrando tecniche di occultamento e ritardo nell'esecuzione. Risoluzioni DNS e Indicatori di Compromissione (IoC)

Durante la sessione di analisi, la componente DNS ha registrato un totale di 161 eventi di risoluzione, e il traffico di rete generato dai processi ha mostrato tentativi di connessione e interrogazioni verso infrastrutture esterne e porte non standard. Si è rilevato inoltre che:

- nelle destinazioni IP e C2, le richieste di rete includono chiamate indirizzate a infrastrutture remote esterne. Nello specifico, il traffico di telemetria e i moduli di cattura dell'ambiente di *sandbox*, tra cui *Suricata* e *IP collector* hanno evidenziato la comunicazione verso IP di simulazione/sandbox ed esterni e tentativi di connessione su porte non convenzionali.
- nel comportamento dei processi, e in contesto di *Process Mapping*, i processi principali responsabili dell'attività di rete o dell'invocazione di connessioni (tra cui `Jvczfhe.exe`, `Muadnrd.exe` e relative processi `cmd.exe` o `WerFault.exe` istanziati come processo figlio) hanno eseguito chiamate di sistema per verificare le impostazioni di *proxy* ("*Checks proxy server information*") e disabilitare i tracciamenti degli eventi del componente *Remote Access Service* (RAS) prima di stabilire la connessione.

1.3.2. Esiti di SURICATA

Dall'analisi dei report forniti dall'ambiente di *sandbox ANY.run* emerge inoltre la rilevazione di indicatori di compromissione e traffico di rete identificati dal motore di sicurezza Suricata. La tabella seguente riassume le relative classi di allerta, le firme riscontrate e le relative interpretazioni:

Classe	Stringa dell'esito/firma	Ipotesi della causa
<i>Not Suspicious Traffic</i>	INFO [ANY.RUN] Attempting to access raw user content on GitHub	Tentativo informativo di accesso a contenuti utente non elaborati su GitHub, classificato come traffico non sospetto.
<i>Potentially Bad Traffic</i>	ET INFO DYNAMIC_DNS Query to a *.duckdns .org Domain	Richiesta DNS effettuata verso un dominio associato a servizi di Dynamic DNS (*.duckdns.org), segnalata come traffico potenzialmente anomalo.
<i>Misc activity</i>	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain	Attività di query DNS generica indirizzata a domini DuckDNS, categorizzata come attività varia o mista.

1.4. Panoramica con matrice MITRE

Sulla base delle evidenze emerse durante l'analisi dinamica del comportamento dei software all'interno della sandbox, le attività individuate sono state mappate secondo il *framework MITRE ATT&CK* per identificare le tattiche e le tecniche impiegate, riassunte nella tabella seguente:

Tattica	Attività registrate
<i>Execution</i>	L'applicazione lancia se stessa in modo autonomo (T1106) e avvia <code>cmd.exe</code> per l'esecuzione di comandi (T1059.003). Viene inoltre eseguito <code>timeout.exe</code> per ritardare i processi. Sulla base delle configurazioni di rete, è ipotizzabile anche il download e l'esecuzione di file arbitrari tramite risorse in ambito Intranet.
<i>Defense evasion</i>	Disabilitazione dei <i>log</i> di tracciamento assegnando alla chiave <code>EnableFileTracing</code> il valore <code>0</code> , impedendo la registrazione degli eventi di rete relativi al componente <i>Remote Access Service</i> , o RAS (T1562.002). Mascheramento delle attività attraverso il rilascio di eseguibili legittimi di Windows (T1036.003).
<i>Discovery</i>	Lettura dal registro di sistema del GUID della macchina, del nome del computer e dei valori d'ambiente (T1012, T1082). Verifica delle informazioni del server <i>proxy</i> , delle lingue supportate dal sistema e del fuso orario locale (T1124).
<i>Command & Control</i>	Connessione verso porte di rete insolite (T1571). Configurazione del registro nell'alveare <code>ZoneMap</code> per l'abilitazione di un proxy locale, finalizzata alla ricezione di risorse remote e alla manipolazione o cattura del traffico di rete.

1.5. Ipotesi di classificazione dei software

Rilevando che le sezioni del report in analisi sulla piattaforma *ANY.run* non contengano elementi che consentano ipotesi di classificazione dei software, si ipotizzano le seguenti classificazioni:

- *loader/dropper*, ovvero software che *sonda* le protezioni del sistema operativo per l'ottenimento da una risorsa remota di un software/*payload malware*, iniettato in un momento successivo. Per le modifiche al registro per il componente *Remote Access Service* (RAS), gli eventi di rete dei software `Jvczfhe.exe` e `Muadnrd.exe` risulteranno assenti.
- *Remote Access Trojan*, ovvero software che abilita l'accesso remoto al sistema operativo per un'entità malevola. Da un'analisi su *MalwareBazar* (bazaar.abuse.ch) ^[3] con l'indirizzo IP contattato dal software `Jvczfhe.exe` durante l'esecuzione di `InstallUtil.exe`, si presume, per questa categoria, si tratti di una versione di *zgRAT* (il quale in generale risulta catturare dati utente del browser e file di portafogli di criptovalute)
- *KeyLogger*, ovvero software che eseguono la cattura in *background* dei tasti premuti dall'utente, e la successiva scrittura delle sequenze, o *keystroke*, catturate in un file locale, e/o in un file in posizione remota. a un'analisi su *MalwareBazar* (bazaar.abuse.ch) ^[3:1] con l'indirizzo IP contattato dal software `Jvczfhe.exe` durante l'esecuzione di `InstallUtil.exe`, si presume, per questa categoria, si tratti di una versione di *Agent Tesla*, il quale risulta possedere funzionalità di cattura delle sequenze di tasti (*keystroke*), della cartella degli appunti (*clipboard*), di acquisizione di *screenshots*, del *setaccio* di credenziali e/o dati segreti.

-
1. <https://github.com/MELITERRER/frew/blob/main/Jvczfhe.exe>. Alla data di redazione di questo report, il collegamento ritorna la pagina 404 di GitHub ↩
 2. <https://github.com/MELITERRER/kioluu/blob/main/Muadnrd.exe>. Alla data di redazione di questo report, il collegamento ritorna la pagina 404 di GitHub ↩
 3. <https://bazaar.abuse.ch/sample/415501cba527ef5e011fd0c180e45545b7602dc25d76a3d0752220f207861baf/> Report di analisi di *Threat Intelligence* con indicazione dell'indirizzo IP contattato dal software `Jvczfhe.exe` durante l'esecuzione di `InstallUtil.exe` ↩ ↩